CASE STUDY

# The eMudhra Certificate Authority Key Compromise: A 2026 Case Study

*A TeamStarWolf case study. Published 2 November 2026; revised 11 November 2026 with the full public record; every source checked as of 11 November 2026.*

## Executive summary

Every padlock in a browser, every package download over HTTPS and every signed Windows driver rests on a short list of certificate authorities that the root programs of Google, Mozilla, Microsoft and Apple have agreed to trust. In October 2026 a researcher working through the public Common CA Database (CCADB) found that eight intermediate certificate authorities run by the Indian CA eMudhra, under its emSign brand, had private keys that anyone could work out from the public certificates. The keys were P-384 elliptic-curve keys whose secret values were integers smaller than 256, so recovering them took moments, and Mozilla says local AI agents did it on a first attempt from a simple capture-the-flag style prompt (**Confirmed** [1]). Anyone holding those keys could sign a certificate for any website, and with the two code-signing keys could sign software, that clients trusting the eMudhra hierarchy would accept (**Confirmed** [3] [34]).

The browser root programs moved in hours. Chrome pushed a block 100 minutes after the report reached it, Firefox's blocklist was complete under three hours after Mozilla received it, and eMudhra revoked all eight intermediates the next morning (**Confirmed** [3] [2] [1]). The harder story is everything that is not a current browser. Go programs, Python's pip, macOS command-line tools, Windows machines that cannot reach Microsoft's update service, network appliances, embedded web views and IoT devices each carry their own idea of who to trust, and their fixes ran on their own schedules: Cisco's fix dates run into 2027, and about two weeks after disclosure Cloudflare still measured more than half of probes from large networks accepting the compromised chain (**Confirmed** [31] [30]). No vendor reports confirmed malicious use through 10 November 2026; certificates forged with the keys appeared within hours of the bug becoming public, and the record cannot rule out quieter use before disclosure against clients that do not enforce Certificate Transparency (**Confirmed** [30] [3]; **Inferred**).

The cause was not a broken algorithm and not an intrusion. eMudhra's own full incident report traces it to a custom script used during a key ceremony on 30 April 2025 that re-created weak key objects after moving keys between hardware security modules, and to the absence of any check that would have caught it (**Confirmed** [1]). The weak keys sat in published certificates for about 18 months, through CCADB disclosure, a cross-signature by Sectigo and audits, and a 2025 public bug about bad CRL signatures that eMudhra now calls an early sign of the defect (**Inferred** from [1] [9]). eMudhra has since announced it is leaving the public TLS business (**Confirmed** [16] [1]).

> Evidence grade: the weakness, the affected certificates, the response by each root program and vendor, and eMudhra's root cause are **Confirmed** from the root programs' own posts, the Mozilla incident bug, vendor advisories, the CVE record and eMudhra's filings. The specific key values, Indian government statements and some certificate counts are known only through secondary reporting or commenters and are **Reported**. Public proofs of key recovery are **Demonstrated**. This study's own conclusions are labelled **Inferred**.

## Key facts at a glance

| Field | Value |
|---|---|
| What failed | Eight eMudhra (emSign) ECDSA P-384 intermediate CA private keys, recoverable from their public certificates [1] |
| Why | Each private key was an integer below 256 instead of a random value near the size of the curve's group order [1] |
| Root cause (eMudhra) | A host-side key-handling script used in a wrap/unwrap round trip after the 30 April 2025 ceremony re-created weak key objects; no key-strength check; near-identical object labels [1] (comment 82) |
| Affected CAs | Six TLS CAs (EM DV, OV and EV TLS CA - G3B and G3C) and two code-signing CAs (EM OV CS CA - G3B and G3C) [1] |
| Certificates carrying the keys | Sixteen: one eMudhra-issued and one Sectigo cross-certificate per key [1] (comments 2, 13 and 82) |
| End-entity certificates from the eight | None, per eMudhra; one TLS CA had been live [1] (comments 2, 10) |
| Reported to the root programs | 17 October 2026, 18:05 UTC, by a researcher signing as "Wayne", with signed proof of key control [1] [4] |
| First block | Chrome CRLSet, 17 October 2026, 19:45 UTC [3] |
| Revocation | eMudhra, 18 October 2026, 09:24 to 09:38 UTC, reason cACompromise; Sectigo cross-certificates, 19 October [1] [18] |
| Root removals | emSign ECC Root CA - G3 from Mozilla NSS (20 October release) and the Chrome Root Store (27 October); seven certificates from Windows (26 October) and Edge (27 October) [2] [3] [24] |
| Identifiers | No CVE for the event itself. CVE-2026-111943, a Go `crypto/x509` record (CWE-299) that AWS also uses for the event, does not name eMudhra; Red Hat's bulletin RHSB-2026-012 groups it with CVE-2026-114406 (RHEL ca-certificates), CVE-2026-91403 (Java) and CVE-2026-113812 (Perl Mozilla::CA), assigned to carry trust-store updates [20] [18] [70] |
| Malicious use | None confirmed by any vendor through 10 November 2026 [30] [31] [24] |
| Outcome | eMudhra exits the global SSL/TLS certificate business; emSign Root CA - G1 issuance hard stop 16 November 2026 [16] [1] |

## Key findings

- **The weakness was in key handling, not in P-384.** All eight private keys were integers below 256, recoverable near instantly; Mozilla recovered them independently in under two hours without knowing the reporter's method (**Confirmed** [1]). CERT-In stresses that the weakness was in key generation, not in the P-384 algorithm (**Confirmed** [34]).
- **eMudhra's cause is a script, three missing checks and one missed warning.** Its full incident report lists four factors: a host-side script that read unwrapped keys out of the module and re-created weak key objects; no key-strength check and no comparison of the certified key with the original; near-identical object labels that let the wrong object sign the certificate request; and a June 2025 CRL anomaly fixed only

at the symptom level (**Confirmed** [1]). eMudhra says its HSMs were not at fault (**Confirmed** as eMudhra's statement [1]).

- **The response from the browser root programs was fast.** Report to Chrome at 18:05 UTC, CRLSet block at 19:45; Mozilla received the report at 20:06 and finished its OneCRL push at 22:59 (**Confirmed** [3] [2]).
- **Certificate Transparency is why browsers were safe, and only browsers.** Google says no TLS certificate chaining to the eight was logged to CT before its block, so none could have been used against CT-enforcing clients (**Confirmed** [3]). Clients that neither enforce CT nor check revocation are where the exposure lives (**Confirmed** [4] [32]).
- **Forged certificates appeared within hours of disclosure.** A public post at 12:15 UTC on 20 October showed a forged certificate for a google.com subdomain, and Cloudflare saw a forged certificate dated 18:19 UTC that day, under an hour after the Mozilla bug became public (**Demonstrated** [37]; **Confirmed** [30]). Cloudflare reads its 22,000 logged handshakes as tests and self-issued origin certificates, not interception (**Confirmed** [30]).
- **The long tail is long.** Cisco lists dozens of affected products with fixes into 2027, AWS lists trust bundles across more than a dozen services, Splunk about 90 products, and Microsoft Windows, Edge, .NET, OpenJDK and Azure images (**Confirmed** [31] [18] [33] [24]).
- **The checks that should have caught it did not look.** Standard certificate linters did not test for small EC private scalars, and Google's internal weak-key scanner only saw certificates in CT logs, so dormant intermediates disclosed only to CCADB were never scanned (**Confirmed** [1]).
- **The same ceremony took down more than the eight.** Eight RSA-4096 intermediates from the same ceremony were revoked on 7 November after eMudhra found they had been handled in host memory against its own practice statement; two of them had issued end-entity certificates since May 2026 (**Confirmed** [1]).

## Top recommendations

1. **Find every trust store, not every host.** Inventory where each client gets its trust: operating system store, language runtime bundle (Python's certifi, Go's denylist, Java keystores), container image, appliance and embedded device, as CERT-In and Talos describe (**Confirmed** [34] [32]).
2. **Patch the client path.** Upgrade Go to 1.26.10 or 1.27.3, pip to 26.2.2 and certifi to 2026.10.19 in every virtual environment, macOS to 27.2.1, 26.7.3 or 15.8.3 for command-line tools, and rebuild container images with the cache disabled (**Confirmed** [21] [35] [28]).
3. **Block by key and by every path.** Removing emSign ECC Root CA - G3 alone does not stop the six Sectigo cross-certificates, which still verify through AAA Certificate Services; block the intermediates themselves or remove all three roots Mozilla named, knowing that may break servers (**Confirmed** [28] [6]).
4. **Keep Windows trust updates flowing.** Leave automatic certificate trust updates on, deliver the disallowed certificate list to disconnected devices, and review disconnected Azure virtual machines (**Confirmed** [26] [24]).
5. **Verify by rejection.** From each client path, confirm that the compromised chain is refused, as CERT-In asks; a version number is not proof (**Confirmed** [34]).

6. **Reissue if you were an eMudhra customer.** Certificates under the G3 hierarchies needed migration, and Chrome stops trusting new emSign Root CA - G1 TLS certificates whose earliest SCT is after 16 November 2026 23:59:59 UTC, and Mozilla sets a TLS distrust-after date of the same moment (**Confirmed** [1] [3] [8]).

## Scope and method

This study covers the eMudhra intermediate CA key compromise from the key ceremony of 30 April 2025 to the planned root removals of 16 November 2026. It replaces the shorter version of this study published on 2 November 2026 and clarifies two points in it: eMudhra's report counts sixteen B and C series keys from the Utimaco ceremony (the figure of 24 in some accounts, including Talos [32], likely also counts the A series issued the same day; Inferred), and the specific key values are known only from secondary reporting (see Part 1). It draws on Mozilla's public incident bug and related bugs, the Chrome, Mozilla, Microsoft and Apple statements, eMudhra's incident page, press releases and stock-exchange filing, vendor advisories from AWS, Cisco, Cloudflare, Splunk, Palo Alto Networks Unit 42, Red Hat, Oracle and the Python and Go projects, the CVE records, India's CERT-In and the Controller of Certifying Authorities, CCADB and root program policy texts, the history of earlier CA distrusts, and the live MITRE ATT&CK pages and the library's own data files. The Intelligence Hub feed served as a starting index of dated headlines; its rows are not cited as evidence. Every source was opened on 11 November 2026. Quotations are kept to a few words.

| Grade | Meaning |
|---|---|
| Confirmed | A primary source was opened: the party's own record of its own action (a root program, the CA's incident report or filing, a vendor advisory, a CVE record, a government page, a policy text) |
| Reported | Known only through a secondary source, such as press coverage, or a third party's unverified claim inside a primary venue, such as a commenter on the incident bug |
| Demonstrated | A public proof that shows the effect, such as a published forged certificate, with no known malicious use |
| Inferred | This study's own reasoning from the cited facts, labelled where it appears |

Where the CA is the only source for a fact about itself, the text says "eMudhra states". Times are UTC unless a source gives another zone. Private key values, certificate serial numbers and fingerprints are not reproduced: the values are themselves the compromised secrets, and the fingerprints are in the root programs' records for anyone who needs to block them.

# Part 1: the technical record

## What a P-384 private key should look like

A P-384 private key is a random integer between 1 and the order of the curve's group, a number of about 384 bits (background from the curve definition). The security of the key rests on that randomness: from the public key, finding the private key should take more work than anyone can do. Mozilla's analysis found that all eight impacted eMudhra keys were integers less than 256, "effectively all-zeroes apart from the last byte", so they can be recovered near instantly, either with a standard discrete-logarithm search or simply by generating the first 256 P-384 keys and comparing (**Confirmed** [1] comment 5). AWS calls the cause "catastrophic entropy failures" in P-384 key generation, with scalar values that were small integers (**Confirmed** [18]); Google says the keys were generated with insufficient randomness (**Confirmed** [3]).

How easy recovery was is part of the record. Mozilla recovered the keys at 21:48 UTC on 17 October, under two hours after receiving the report and without knowing how the reporter had done it (**Confirmed** [1] comment 0). It also reports that local AI agents recovered the keys on a first attempt from a simple CTF-style prompt (**Confirmed** as Mozilla's statement [1] comment 5). See AI Threats 2026 for how far that lowers the bar in other settings.

Specific scalar values for the eight keys circulate in secondary reporting, for example OffSec's write-up, but no primary source opened for this study lists them (**Reported** [38]). This study does not repeat them.

## How the weak keys were made

eMudhra's Full Incident Report, posted to the Mozilla bug on 10 November 2026, gives the CA's account (**Confirmed** as eMudhra's statement [1] comment 82):

- One key-generation ceremony on 30 April 2025 produced 16 subordinate CA key pairs in the B and C series, RSA-4096 and ECDSA P-384, generated correctly on Utimaco HSMs.
- The keys then went through an approved wrap and unwrap round trip, driven by a custom Python key-handling script, so they could be moved to Crypto4A HSMs in facilities in the US and the EU.
- **Factor 1:** a host-side script error. After unwrapping, the script read the private key value out of the module into host memory and re-created a key object. The re-created ECDSA objects were the weak ones.
- **Factor 2:** no key-strength check, and no comparison of the key that was certified with the key originally generated.
- **Factor 3:** nearly identical object labels let the wrong object be used to create the certificate signing request.
- **Factor 4:** the June 2025 CRL signature anomaly was fixed only at the symptom level.
- eMudhra states the HSMs functioned correctly and were not at fault.

eMudhra's earlier accounts differ from the final one. Its 19 October comment said CRLs for these intermediates were first signed with the original strong keys, failed to verify, and were re-signed with the flawed keys (**Confirmed** [1] comment 11). Its press statement of 21 October pointed to a flaw in a wrap and unwrap step that produced "a second, weak key set" that was the one published to root stores, with the root cause not yet confirmed (**Confirmed** [15]). Its public incident page said in Update 3 that the exact root cause was not yet confirmed and in a leadership note that "a script error" produced the weak keys (**Confirmed** [14]).

## The A series and why it was spared

Mozilla could not recover the P-384 keys of eMudhra's A series intermediates or of the replacement A-1 series. eMudhra states those were generated on a different HSM platform, Entrust's, for domestic deployment, and are not affected (**Confirmed** [1] comment 82). A separate bug reports that the A series, issued on 30 April 2025 and revoked on 30 May 2025, is missing from eMudhra's 2024-25 WebTrust audit reports, and that a Certificate Problem Report sent on 3 November 2026 got no reply (**Confirmed** as the bug's report [10]).

## The warning in 2025

The six G3B and G3C TLS intermediates had invalid CRL signatures in 2025. Mozilla Bug 1970728, opened on 5 June 2025, records the anomaly from 29 May to 6 June 2025 (**Confirmed** [9]). eMudhra now says this was an early sign of the key-handling defect (**Confirmed** [1] comment 82), and commenters on the 2026 bug argue the weak keys could have been caught then (**Reported** [1]). The certificates carry the weak public keys, so a CRL signed with the original strong key does not verify against them, which is consistent with what eMudhra later described (Inferred from [1] comments 11 and 82).

A second CRL oddity surfaced during the incident: a CRL for emSign Root TLS CA - G1, CRL number 11 dated 14 October 2026, carried a signature that did not verify under that root, and a community member later matched it to an OCSP responder certificate's key (**Reported**, a commenter's finding on the bug [1] comment 7). A third bug records that eMudhra's CRLs were blocked for certain User-Agent headers (**Confirmed** [11]).

## What the keys allowed

Google says the compromise let anyone forge trusted HTTPS certificates to impersonate any website on clients that had not removed trust (**Confirmed** [3]). Mozilla says an attacker who could intercept a connection could impersonate websites and read or modify traffic (**Confirmed** [2]). CERT-In adds that fraudulent TLS certificates could enable credential theft and financial fraud, and that the two code-signing keys could make malware appear signed by a trusted publisher (**Confirmed** [34]). Microsoft frames the event as a problem in eMudhra's hierarchy and not a compromise of Microsoft systems (**Confirmed** [24]).

Two things limited that power. The eight intermediates had no Certificate Transparency entries, so CT-enforcing browsers would have rejected or exposed any certificate forged under them (**Confirmed** [4] [3]). And clients that enforce fail-closed revocation checking, OCSP or CRL, were not affected once the intermediates were revoked (**Confirmed** [18]).

## Discrepancies in the record

- **Which root.** eMudhra's report names the TLS issuer "emSign Root TLS CA - G3" and the code-signing issuer "emSign Root CS CA - G3" [1]; Google, Mozilla and CERT-In act on "emSign ECC Root CA - G3" as the root that signed the compromised intermediates [3] [7] [34]; AWS lists AAA Certificate Services, emSign Root TLS CA - G3 and emSign ECC Root CA - G3 [18]; Talos names the TLS and CS G3 roots [32]. Mozilla had only posted its intent to include emSign Root TLS CA - G3 on 2 October 2026 [13], so one reading is that the dedicated G3 roots were not yet in Mozilla's store and the trusted path ran through emSign ECC Root CA - G3 and the Sectigo cross-certificates; Apple states that the emSign Root TLS CA - G3 certificate chains to emSign ECC Root CA - G3 (Confirmed [28]), which supports this reading (Inferred for the rest; not checked against CCADB).
- **Eight or six.** Google's post reports eight compromised subordinate CAs and later refers to "these six intermediate CAs", the six TLS CAs of the eight (**Confirmed** [3]).

- **NSS version.** Mozilla's blog names NSS 3.131.1 as the release that removed the root [2]; Bug 2084101 records the fix in NSS 3.132 [7] (**Confirmed** for both statements).
- **Revocation date.** eMudhra and CERT-In give 18 October; reports attributed to India's Ministry of Electronics and Information Technology (MeitY) give 19 October, the date Sectigo revoked its cross-certificates (**Confirmed** [1] [34] [18]; **Reported** [45]; Inferred for the explanation).
- **Who reported.** Google and Mozilla say a security researcher reported to their root programs; Cisco's advisory credits eMudhra with reporting the issue to Cisco (**Confirmed** [3] [2] [31]; Inferred for the reading).
- **How many certificates to migrate.** eMudhra gave about 30,000 certificates on the Mozilla bug and about 30,800 under the affected G3 hierarchies on its incident page (**Confirmed** [1] [14]).

## Part 2: the affected hierarchy

### The eight ECDSA intermediates

| CA | Operator entity | Use | Issued by (per eMudhra's report) | Trusted by |
|---|---|---|---|---|
| EM DV TLS CA - G3B | eMudhra BV | TLS, domain validated | emSign Root TLS CA - G3 | Chrome, Mozilla, Microsoft, Apple programs |
| EM OV TLS CA - G3B | eMudhra BV | TLS, organization validated | emSign Root TLS CA - G3 | Chrome, Mozilla, Microsoft, Apple programs |
| EM EV TLS CA - G3B | eMudhra BV | TLS, extended validation | emSign Root TLS CA - G3 | Chrome, Mozilla, Microsoft, Apple programs |
| EM DV TLS CA - G3C | eMudhra Inc | TLS, domain validated (the one live CA) | emSign Root TLS CA - G3 | Chrome, Mozilla, Microsoft, Apple programs |
| EM OV TLS CA - G3C | eMudhra Inc | TLS, organization validated | emSign Root TLS CA - G3 | Chrome, Mozilla, Microsoft, Apple programs |
| EM EV TLS CA - G3C | eMudhra Inc | TLS, extended validation | emSign Root TLS CA - G3 | Chrome, Mozilla, Microsoft, Apple programs |
| EM OV CS CA - G3B | eMudhra BV | Code signing | emSign Root CS CA - G3 | Microsoft |
| EM OV CS CA - G3C | eMudhra Inc | Code signing | emSign Root CS CA - G3 | Microsoft |

Source: Mozilla's opening comment and eMudhra's report (**Confirmed** [1] comments 0 and 82). Talos lists the same eight with CCADB records A012294 to A012308 (**Confirmed** [32]). eMudhra says the G3B and G3C intermediates were created for its European and US operations, that only one was put into production, that it issued no end-entity certificates, and that the code-signing issuers issued none (**Confirmed** as eMudhra's statement [1] comments 2 and 10). eMudhra disabled the live CA, EM DV TLS CA - G3C, on 17 October (**Reported**, the reporter relaying eMudhra's email [1] comment 2).

## The Sectigo cross-certificates

Sectigo cross-certified the ECDSA set under its AAA Certificate Services root, and revoked eight cross-certificates on 19 October 2026 (**Confirmed** [1] comments 6 and 13; the AAA Certificate Services root is named in [18] and [28]). Cisco's advisory says the cross-signing took place in May 2025 (**Reported** as Cisco describing third parties [31]). Sectigo says AAA Certificate Services had already been removed from the Chrome and Mozilla stores but remains in the Microsoft and Apple programs (**Confirmed** [1] comment 6). That is why Apple warns that removing emSign ECC Root CA - G3 alone does not stop the six cross-signed TLS certificates verifying through AAA Certificate Services, and why Apple blocks twelve TLS intermediate certificates, two per CA (**Confirmed** [28]).

## The RSA set from the same ceremony

The ceremony's other eight keys, RSA-4096 subordinates in the G2B and G2C series, were revoked on 7 November 2026 with reason cessationOfOperation after an assessment against section 6.2.6 of eMudhra's certification practice statement, which covers private key transfer. eMudhra says the RSA key integrity was intact. The G2C TLS and code-signing issuers had been in production since May 2026 and had issued end-entity certificates (**Confirmed** [1] comment 82).

## The roots and what happens to them

| Root | What happens | Source |
|---|---|---|
| emSign ECC Root CA - G3 | Removed from NSS (Bug 2084101, filed 20 October, FIXED); removed from the Chrome Root Store, reaching devices on 27 October PDT; blocked by Apple; probably among the six eMudhra G3 roots Microsoft removed on 26 October (the MSRC post does not list them by name; Inferred) | [7] [3] [28] [24] |
| emSign Root TLS CA - G3 | Listed by AWS as an affected root; named by Mozilla among three roots to consider removing | [18] [6] |
| AAA Certificate Services (Sectigo) | Listed by AWS; named by Mozilla among three roots to consider removing; one AAA cross-signature among the seven certificates Microsoft removed | [18] [6] [24] |
| emSign Root CA - G1 (RSA) | Chrome 153 and later stop trusting TLS certificates chaining to it whose earliest SCT is after 16 November 2026 23:59:59 UTC; Mozilla removes email trust and sets a TLS distrust-after date of the same moment (Bug 2089115); eMudhra sets a hard stop for G1 issuance at 16 November 23:59 | [3] [8] [1] |
| The remaining 10 eMudhra roots | Removed from Windows and the Microsoft Trusted Root Program starting 16 November 2026; Edge and WebView2 remove default trust for four named roots | [24] |

Microsoft's two counts, seven certificates in October and ten remaining roots in November, describe different sets (**Confirmed** [24]). eMudhra's incident page lists an Apple removal of G1 on 30 November (**Reported**: eMudhra describing Apple [14]).

## Who held certificates under G3

eMudhra estimated about 30,000 certificates to migrate when it stopped issuance under G3, about 97 percent of them issued through ACME (**Confirmed** [1] comment 19). Its incident page puts about 30,800 certificates under the affected G3 hierarchies in one US client ecosystem, now moved to the G1 RSA pathway, with G1 TLS issuance to stop once that federation's transition completes (**Confirmed** as eMudhra's statement [14]). Commenters on the Mozilla bug identify the ecosystem as InCommon, run by Internet2 for US universities and research institutions on eMudhra's CertiNext platform, with the issuer InCommon Intermediate CA - DVG3C; eMudhra does not name it (**Reported** [1] comment 69). These certificates sat under other intermediates of the G3 hierarchy, not under the eight, which issued none (Inferred from [1] [14]).

## Part 3: the timeline

| Date and time (UTC) | Event | Source | Grade |
|---|---|---|---|
| 30 Apr 2025 | Key ceremony produces 16 B and C series subordinate keys on Utimaco HSMs; a custom script moves them for Crypto4A HSMs and re-creates weak ECDSA objects. The A series is issued the same day on a different platform | [1] c82; [10] | Confirmed |
| May 2025 | Sectigo cross-signs the eight ECDSA intermediates under AAA Certificate Services | [31] | Reported |
| 29 May to 6 Jun 2025 | Invalid CRL signatures on the six G3B and G3C TLS intermediates; Bug 1970728 opened 5 June | [9] | Confirmed |
| 30 May 2025 | A series intermediates revoked | [10] | Confirmed |
| 2026, before the incident | eMudhra's transition plan for dual-purpose roots proposes a 15 June 2026 distrust-after date for its C1 and C3 roots; Mozilla notes a requested date does not itself change trust status (Bug 2018979) | [12] | Confirmed |
| 2 Oct 2026 | Mozilla posts its intent to approve inclusion of four new eMudhra roots, last call 9 October; a participant replies he is not impressed by eMudhra's recent incident performance | [13] | Confirmed |
| 14 Oct 2026 | A CRL for emSign Root TLS CA - G1 (number 11) carries a signature that does not verify under that root | [1] c7 | Reported (a commenter's finding) |
| 17 Oct, 16:27 | The reporter's run over a CCADB corpus finds the EC key break | [1] c2 | Confirmed |
| 17 Oct, 18:05 | Report with signed attestations emailed to Apple, Chrome, Microsoft, Mozilla and eMudhra; the Chrome Root Program receives it | [1] c2; [3] | Confirmed |
| 17 Oct, 19:45 | Chrome lands a CRLSet update blocking the intermediates' SPKI hashes, no browser update or restart needed | [3] | Confirmed |
| 17 Oct, 20:06 | Mozilla receives the report, forwarded by Chrome, with proof of key control | [2]; [1] | Confirmed |
| 17 Oct, 21:48 | Mozilla independently recovers the private keys | [1] c0 | Confirmed |
| 17 Oct, 22:59 | OneCRL distribution complete for standard Firefox configurations | [2] | Confirmed |
| 17 Oct | eMudhra disables EM DV TLS CA - G3C, the one live intermediate | [1] c2 | Reported (the reporter relaying eMudhra) |
| 18 Oct, 09:24 to 09:38 | eMudhra revokes all eight intermediates, reason cACompromise; its chairman later says within 14 hours of discovery | [1] c10; [14] | Confirmed |
| 18 Oct, 12:06 | Mozilla opens Bug 2083449 in CA Certificate Compliance, tagged ca-misissuance | [1] | Confirmed |
| 19 Oct | Sectigo revokes the eight cross-certificates; downstream trust stores told | [1] c6, c13; [18]; [4] | Confirmed |

| Date and time (UTC) | Event | Source | Grade |
|---|---|---|---|
| 19 Oct | Go 1.27.3 and 1.26.10 released with the `crypto/x509` fix | [21] | Confirmed |
| 19 Oct, about 17:00 | Cloudflare becomes aware and starts patching high-impact systems | [29] | Confirmed |
| 19 Oct, about 22:00 | Android and Googlebooks receive the equivalent block through Google Play Services (the post names the weekday, Monday) | [3] | Confirmed |
| 20 Oct, 02:00 and 09:15 | Cloudflare One Client and WARP updates, then the cloudflared Tunnel update | [29] | Confirmed |
| 20 Oct, 12:15 | Public post shows independent key recovery with a forged certificate for a google.com subdomain | [37] | Demonstrated |
| 20 Oct | Mozilla notes multiple people recovered the keys, some publicly, and orders emergency removal of emSign ECC Root CA - G3; Bug 2084101 filed; eMudhra stops issuing under G3 | [1] c18, c19; [7] | Confirmed |
| 20 Oct | Firefox 158.0.1, ESR 115.43.1, ESR 153.5.1 and NSS 3.131.1 released | [2] | Confirmed |
| 20 Oct | Mozilla publishes CVE-2026-113470 for the bundled OneCRL update; CPANSec publishes CVE-2026-113812 for Perl Mozilla::CA before 20261020 | [74] [73] | Confirmed |
| 20 Oct | Microsoft updates the Windows Disallowed Certificate Trust List for the eight CAs; separate CRLSet for Edge and WebView2 | [24] | Confirmed |
| 20 Oct | Google posts its account and announces root removal for 27 October; CT logs updated to reject chains to the compromised CAs | [3] | Confirmed |
| 20 Oct | Mozilla advises trust store operators on dev-security-policy and oss-security; eMudhra's incident page first published | [5] [6] [14] | Confirmed |
| 20 Oct, 18:19 | Earliest forged certificate Cloudflare observed, under an hour after the Mozilla bug went public | [30] | Confirmed |
| 20 Oct, 19:20 and 22:20 | Cloudflare finishes CDN and Zero Trust mitigations, then publishes its explainer | [29] | Confirmed |
| 21 Oct, 08:29 | Firefox for Android 158.0.2 fixes clients that did not apply the bundled OneCRL list right after startup | [2] | Confirmed |
| 21 Oct | Go publishes CVE-2026-111943 and GO-2026-6809; Amazon Linux rebuilds Go packages | [20] [21] [19] | Confirmed |
| 21 Oct | Red Hat publishes bulletin RHSB-2026-012 (Critical) and CVE-2026-114406 for RHEL ca-certificates; Oracle publishes CVE-2026-91403 and a Security Alert for Java | [70] [72] [71] [75] | Confirmed |
| 21 Oct | AWS deploys root removal to the live shared AWS trust store | [18] | Confirmed |
| 21 Oct | Cisco Talos advisory and Snort SIDs 67363 to 67374; CERT-In advisory CIAD-2026-0050 | [32] [34] | Confirmed |
| 21 Oct | eMudhra press statement and stock-exchange filing: no infrastructure compromise, global TLS about 1 percent of revenue | [15] [17] | Confirmed |

| Date and time (UTC) | Event | Source | Grade |
|---|---|---|---|
| 21 Oct | MeitY reportedly forms a special team and calls the impact very limited | [45] [46] | Reported |
| 22 Oct | eMudhra's board decides to withdraw from the global SSL/TLS business; Sectigo certificates offered as an alternative | [16] [14] | Confirmed |
| 22 Oct | CA/Browser Forum Server Certificate Working Group discusses ECDSA intermediates with weak keys; HARICA to draft ballot text | [40] | Confirmed |
| 22 Oct | Blocked on Apple platforms from this date, per the community explainer site; Apple's own page gives no start date | [4] [28] | Confirmed (as each source states) |
| 23 Oct, 16:00 GMT | Cisco publishes informational advisory cisco-sa-emudhra-info-ScS22A1r | [31] | Confirmed |
| 24 Oct, 20:00 PDT | AWS publishes bulletin 2026-150-AWS | [18] | Confirmed |
| 25 Oct | eMudhra states on the bug it has decided to exit the public TLS business; Bug 2085612 on blocked CRL access opened | [1] c43; [11] | Confirmed |
| 26 Oct | Microsoft out-of-band update removes seven certificates from the Windows trust list; KB5134133 for Windows 11 | [24] [25] | Confirmed |
| 26 Oct | KB5134125 for Windows 10 21H2 and 22H2 | [27] | Reported |
| 27 Oct | Same seven certificates removed from Edge; Chrome Root Store removal reaches devices (PDT); Chrome Root Program posts its review (comment 50); Splunk advisory SVD-2026-1014 | [24] [3] [1] [33] | Confirmed |
| 28 Oct | AWS deadline for ALB OIDC and JWT customers; Microsoft admin guidance MC1529467 | [18] [26] | Confirmed |
| 30 Oct | Cloudflare publishes its exploitation and patching tracker; eMudhra names KPMG as independent external reviewer; CISA's ADP scoring on the CVE record | [30] [14] [20] | Confirmed |
| 31 Oct | Red Hat updates RHSB-2026-012 | [70] | Confirmed |
| 3 Nov | A Certificate Problem Report on the A series goes unanswered | [10] | Confirmed |
| 4 Nov | Google adds the emSign Root CA - G1 SCT cutoff for Chrome 153 and later | [3] | Confirmed |
| 5 Nov | eMudhra incident page and AWS bulletin last updated | [14] [18] | Confirmed |
| 6 Nov | Bug 2090128 on the A series missing from audit reports | [10] | Confirmed |
| 7 Nov | Eight RSA G2B and G2C intermediates revoked, cessationOfOperation | [1] c82 | Confirmed |
| 9 Nov | Apple support article 149555 published | [28] | Confirmed |
| 10 Nov | eMudhra Full Incident Report posted (comment 82); Microsoft update; Cisco advisory v1.9 | [1] [24] [31] | Confirmed |

| Date and time (UTC) | Event | Source | Grade |
|---|---|---|---|
| 16 Nov (planned) | G1 issuance hard stop; Chrome and Mozilla G1 cutoffs; Microsoft starts removing the remaining 10 roots | [1] [3] [8] [24] | Confirmed (planned) |
| 30 Nov and 4 Dec (planned) | eMudhra's inventory deadline and independent review deadline | [1] | Reported (eMudhra self-report) |

# Part 4: was it exploited?

## What the record shows

- **Forged certificates after disclosure.** Cloudflare saw certificates forged under the weak keys after they leaked, one dated 20 October 18:19 UTC, and says the keys "appear to have been used" to forge certificates within hours of the weakness becoming public (**Confirmed** [30]). A public post at 12:15 UTC that day demonstrated a forged certificate for a google.com subdomain (**Demonstrated** [37]).
- **Handshakes, mostly tests.** After its Pingora logging finished rolling out on 21 October, Cloudflare logged about 22,000 attempted outbound handshakes presenting the weak keys in roughly a week. About two thirds were fetches of test sites and almost all the rest went to origins that had set up a certificate for themselves under the weak intermediate. Every handshake set to verify the certificate was refused. About 160 named other organizations' domains, some tied to consumer IoT, and would have failed hostname verification; Cloudflare reads them as servers' default certificates, not interception attempts (**Confirmed** [30]).
- **No interception found, none ruled out.** Cloudflare found no evidence of the weak keys being used to intercept its own connections and says that "does not exclude carefully targeted interception" (**Confirmed** [30]). Its 20 October review had found no active exploitation on Cloudflare services (**Confirmed** [29]).
- **Certificates in CT.** A commenter on the Mozilla bug reported about 107,107 certificates signed with six of the keys logged on 20 and 21 October, including proof-of-concept certificates for google.com; the bug does not verify the figure (**Reported** [1] comment 44). SecurityOnline reports more than 106,000 such certificates and attributes them to researchers and enthusiasts testing the keys (**Reported** [39]). Google's statement that nothing was logged before its block covers a different window, and its note that CT logs were updated to reject the chains does not say which logs, so the two are not reconciled (Inferred from [3] [1]).

## What each party says

| Party | Statement | Date | Source | Grade |
|---|---|---|---|---|
| Google | No CT log held certificates from the affected CAs before the block, so none could be used against CT-enforcing clients | 20 Oct | [3] | Confirmed |
| Chrome Root Program | Covert exploitation against Chrome users was not possible, because CT enforcement would expose the certificates | late Oct | [1] | Confirmed |
| Mozilla | Expects abuse of the keys soon; asks operators to act fast | 20 Oct | [6] | Confirmed |
| CERT-In | Public disclosures did not establish confirmed malicious exploitation as of 21 October | 21 Oct | [34] | Confirmed |
| Cisco Talos | No malicious incidents seen in the wild as of 21 October 14:00 UTC | 21 Oct | [32] | Confirmed |
| Cisco PSIRT | Not aware of malicious use | 10 Nov (v1.9) | [31] | Confirmed |
| Splunk | No resulting compromise of its products, services or certificates | 27 Oct | [33] | Confirmed |
| Microsoft | Not a compromise of Microsoft systems; no confirmed active exploitation | 26 Oct to 10 Nov | [24] | Confirmed |
| Unit 42 | Reports no observed exploitation | 22 Oct | [36] | Confirmed |
| eMudhra | Not aware of evidence the weak keys were recovered or exploited before disclosure | Oct to Nov | [14] | Confirmed (as eMudhra's statement) |

The synthesis: certificates forged under the weak keys appeared only after public disclosure, none were in CT before the block, and no vendor reported confirmed malicious interception through 10 November 2026. Misuse before disclosure can be neither shown nor ruled out, because the intermediates never logged leaves to CT and the clients that would have accepted a forged certificate are the ones that do not report to anyone (Inferred from [30] [3] [24] [31]).

## Who could still be fooled

Talos places the residual exposure in software that ignores revocation or keeps its own CA store: Go-based cloud-native tools such as Docker, Kubernetes, Terraform and Prometheus, proxies, VPN clients, CI/CD runners, package managers, industrial IoT and embedded devices (**Confirmed** [32]). Cloudflare's probe of about 50 million challenge pages over a week found current browsers mostly patched, but Android WebView and other embedded browsers still accepting the compromised chain 30 to 40 percent of the time, and more than half of probes from large networks still accepting it, with the trend flat after the first weekend; Cloudflare cautions that bots skew the data (**Confirmed** [30]).

# Part 5: the governance view

## The rules that framed the response

| Rule | What it requires | Source | Grade |
|---|---|---|---|
| CCADB Incident Reporting Guidelines v3.2 (effective 20 Mar 2026) | Within 72 hours a preliminary or full report, or a response to a third-party report; the full report within 14 days of initial disclosure, in Bugzilla CA Certificate Compliance, with set sections from Summary to Action Items; answers to questions within 7 days | [47] | Confirmed |
| Mozilla Root Store Policy v3.1 (effective 1 Jul 2026) | Any policy failure is an incident under the CCADB guidelines; serious security incidents go in a secure bug; Mozilla may remove trust at any time for any reason; no exceptions to TLS revocation deadlines; intermediates disclosed in CCADB within 7 days and before issuance | [48] | Confirmed |
| Chrome Root Program Policy v1.8 (5 Feb 2026) | Public incident disclosure in Bugzilla regardless of perceived impact; precertificates logged before issuance from 15 June 2026; inclusion at Google's sole discretion; partial distrust through SCTNotAfter phase-outs; 15-year root key term; dedicated serverAuth hierarchies | [49] | Confirmed |
| Chrome CT policy | All publicly trusted TLS certificates must be CT compliant to validate, with SCTs from two or three logs and at least two log operators | [50] | Confirmed |
| RFC 6962 (June 2013) | Certificate Transparency: public logs so anyone can audit CA activity, with the long-term aim that clients refuse unlogged certificates | [51] | Confirmed |
| Chrome CT enforcement (announced 6 Feb 2018) | All TLS server certificates issued after 30 April 2018 must comply with the Chromium CT policy | [52] | Confirmed |

## How the machinery worked this time

The report went to every major root program at once, with signed attestations: the reporter, Wayne, proved control of each key by signing the message "We have a problem here - Wayne" with all eight, and the proof files are published on the community explainer site (**Confirmed** [4] [1]). No separate write-up by the reporter is known (Inferred [4]). The fast tools fired first: Chrome's CRLSet and Mozilla's OneCRL push the same day, Android's Play Services update two days later, the Windows Disallowed list on 20 October (**Confirmed** [3] [2] [24]). Root removal followed: an unscheduled Firefox release and NSS update on 20 October, the Chrome Root Store on 27 October (**Confirmed** [2] [7] [3]). For the remaining RSA root, Chrome and Mozilla reused the SCT-date distrust used for Entrust: certificates first logged after 16 November 2026 23:59:59 UTC lose trust, and Mozilla's bug uses SCT checks to stop backdated notBefore dates (**Confirmed** [3] [8]; Inferred for the lineage).

Mozilla advised other trust store operators that no action was needed for clients that fail closed on revocation, to block the listed intermediates where possible, and otherwise to consider removing the listed roots, and said it did not believe other CAs were affected (**Confirmed** [5]). Google reviewed its root stores and found no other keys with the same weak-entropy failure (**Confirmed** [3]).

The CA's full report arrived on 10 November, after the 14-day window that the CCADB guidelines set from initial disclosure on 18 October; commenters cited the guideline and Mozilla's policy on delayed revocation, and eMudhra set 9 November for the report, citing the KPMG review (**Confirmed** [1] [47]; Inferred for the

lateness count). One commenter called the incident the most catastrophic for the WebPKI since Flame (**Reported**, opinion [1]).

## What the checks missed

The Chrome Root Program's review on the bug (comment 50) is the clearest account of the gap. Standard linters (pkimetal, badkeys, zlint, pkilint) did not check for small EC private scalars. Google's internal paranoid_crypto pipeline scanned only certificates logged to CT, and the eight intermediates had never issued a CT-logged leaf, so dormant intermediates disclosed only to CCADB were never scanned. Chrome has since added paranoid_crypto checks to its workflows, found no other weak CA keys among trusted roots and CCADB-disclosed CAs, and proposed mozilla/CCADB-Tools#185 to gate CA disclosure on weak-key checks (**Confirmed** [1] comment 50). The same comment notes that eMudhra had filed four Chrome root applications since 2022, three denied and the fourth since denied (**Confirmed** [1]).

At the CA/Browser Forum's Server Certificate Working Group on 22 October, members discussed "ECDSA intermediate certificates with weak keys" and the lack of explicit minimum checks for weak ECDSA private scalars in the Baseline Requirements; HARICA agreed to draft ballot text. The minutes do not name eMudhra (**Confirmed** [40]).

## The lineage of CA distrusts

| Year | CA | Trigger | What it changed | Source | Grade |
|---|---|---|---|---|---|
| 2011 | DigiNotar | Intrusion: a fraudulent DigiNotar certificate for Google used in attempted man-in-the-middle attacks, mainly on users in Iran; the Dutch government said DigiNotar was broken into in July 2011 and took over its certificate systems | Browsers removed an entire CA within days; Chrome rejected all DigiNotar-operated CAs on 3 Sep 2011 | [53] [54] [55] | Confirmed |
| 2011 | DigiNotar | Fox-IT's interim count of at least 531 rogue certificates | Scale of the intrusion | [56] | Reported |
| 2015 | Symantec | Google found more misissued Symantec certificates in CT logs within minutes | CT required for all Symantec certificates from 1 June 2016: CT as an enforcement lever | [57] | Confirmed |
| 2016 | WoSign and StartCom | Deception: backdated SHA-1 certificates and a concealed acquisition; GitHub reported an unauthorized certificate on 17 Aug 2016 | Distrust of certificates with notBefore after 21 Oct 2016; audits from one firm no longer accepted; reapplication with new roots | [58] [59] | Confirmed |
| 2017 | Symantec | Oversight failure: other organizations issued without oversight | Staged distrust in Chrome 66 and 70; issuance moved to DigiCert-run infrastructure | [60] | Confirmed |
| 2022 | TrustCor | Ownership and integrity concerns over links to a spyware SDK distributor, with no misissuance found | Distrust-after dates of 30 Nov 2022 under Mozilla's discretion clause | [61] [62] | Confirmed |
| 2024 | Entrust | Six years of compliance failures and unmet commitments | SCT-date distrust: Chrome 131 distrusts certificates whose earliest SCT is after 11 Nov 2024; Mozilla distrust-after 30 Nov 2024 | [63] [64] | Confirmed |
| 2026 | eMudhra | Key compromise through weak key generation and handling | Chrome added weak-key checks to its workflows and scanned CCADB-disclosed CAs; CCADB-Tools#185 proposes gating CA disclosure on weak-key checks; HARICA agreed to draft ballot text on minimum checks for ECDSA private scalars | [1] [40] | Confirmed |

eMudhra is the first distrust in this lineage triggered by CA keys that were weak from the start, rather than by intrusion, deception, oversight failure, ownership concerns or chronic compliance failure (Inferred). The response reused every tool the lineage built: same-day blocklists keyed on the public key, CT as the evidence that no forged certificate reached CT-enforcing clients, root removal for the signing root, and the Entrust-style SCT cutoff for the remaining G1 root (Inferred from [3] [2] [8] [63]).

# Part 6: the Indian context and the business

eMudhra runs two businesses that the incident separated sharply. The Controller of Certifying Authorities (CCA) lists e-Mudhra as one of 23 licensed Certifying Authorities in India (**Confirmed** [41]). Under the Information Technology Act 2000, section 3 gives digital signatures legal standing, and the CCA, appointed under section 17 with its office from 1 November 2000, licenses CAs and operates the Root Certifying Authority of India (**Confirmed** [42]). The CCA's eSign service signs on the eSign provider's back end after e-KYC authentication by biometrics or one-time password, while conventional Digital Signature Certificates (DSCs) sit on hardware tokens (**Confirmed** [43]). ICRA's June 2024 rating rationale put eMudhra's DSC market share at about 40 percent in FY2024, with 3.08 million DSCs issued that year to customers including large banking and financial services firms, government entities and corporates (**Confirmed** [44]).

CERT-In draws the line: the CCA-regulated DSC and eSign issuance was not affected, and the incident occurred in the globally trusted certificate business audited under WebTrust by BDO International (**Confirmed** [34]). eMudhra's stock-exchange filing of 21 October says the global TLS business is about 1 percent of revenue and runs on infrastructure separate from the Indian DSC business, that there was no infrastructure compromise or data breach, and that the reputational risk cannot be quantified (**Confirmed** [17]). Its press statement the same day says an independent researcher reported the issue to Apple, Google, Microsoft and Mozilla (**Confirmed** [15]). News reports say MeitY set up a special team, called the impact on Indian websites and apps very limited and short-lived, and said it is not involved in the WebTrust audit; no MeitY or Press Information Bureau primary was found (**Reported** [45] [46]).

On 22 October eMudhra's board decided to withdraw voluntarily from the global SSL/TLS certificate business, citing compliance costs, free certificates from large providers and social-media scrutiny; the G1 RSA roots continue until customers transition, and revocation services continue until every issued certificate expires or is replaced (**Confirmed** [16]). eMudhra offered Sectigo certificates as an alternative from 22 October and named KPMG as independent external reviewer on 30 October (**Confirmed** [14]).

# Part 7: the vulnerability-management view

## Whose CVE is it?

CVE-2026-111943 is a record assigned by the Go project as CNA, titled "Distrust compromised intermediate certificates in crypto/x509". It adds a denylist so that `Certificate.Verify` returns an error for the known untrustworthy intermediates; affected versions are Go before 1.26.10 and 1.27.0-0 before 1.27.3; the weakness is CWE-299, Improper Check for Certificate Revocation. It was reserved on 17 October and published on 21 October, and the record does not name eMudhra (**Confirmed** [20]). The Go vulnerability report GO-2026-6809 covers the same fix (**Confirmed** [21]). CISA's ADP container scores it CVSS 3.1 6.8 (`AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N`), with SSVC Exploitation none, Automatable no and Technical Impact total (**Confirmed** [20]).

AWS uses CVE-2026-111943 as the identifier for the eMudhra key recovery across its trust bundles, names CVE-2026-113470 (the ca-certificates root removal) as the primary fix, and CVE-2026-114406 for the operators' remaining certificates (**Confirmed** [18]). Amazon Linux rebuilt its Go-based packages against CVE-2026-111943 as defense in depth (**Confirmed** [19]). A Qualys post whose address names a second identifier, CVE-2026-111944, describes only CVE-2026-111943, and the CVE Services API returns no record for CVE-2026-111944 (**Confirmed** [23] [22]).

Red Hat's security bulletin RHSB-2026-012, public on 21 October and updated on 31 October, rates the event Critical and says it is not a software vulnerability: the identifiers were assigned to help distribute preventative trust-store updates (**Confirmed** [70]). It groups four. CVE-2026-114406, which Red Hat assigned for the RHEL ca-certificates package, names eMudhra in its title and carries CWE-295 (**Confirmed** [70] [72]). CVE-2026-111943 is the Go record above. CVE-2026-91403 is Oracle's: its Security Alert ships Java SE and GraalVM updates that distrust the eMudhra intermediates, while the CVE record's own text describes a JSSE flaw with a CVSS 3.1 score of 9.1 and does not name eMudhra (**Confirmed** [71] [75]). CVE-2026-113812, assigned by CPANSec, covers the Perl Mozilla::CA bundle before version 20261020, which still carried emSign ECC Root CA - G3, with CWE-295 (**Confirmed** [73]). Mozilla's own record, CVE-2026-113470, covers the Firefox releases that bundle the updated OneCRL list for clients whose remote settings are disabled or unreachable (**Confirmed** [74]). Red Hat lists RHEL 6 to 10, and every product and container image built on them, as carrying the compromised certificates in the trust store, and asks customers to rebuild their own containers when the base images update (**Confirmed** [70]).

The lesson for a program that keys work on CVE ids: the event has no CVE of its own. Tracking it by CVE-2026-111943 alone catches Go and the AWS bulletin; adding Red Hat's four ids and Mozilla's catches RHEL, Java, Perl and Firefox; and both miss Windows, Apple, Python, Cisco and Splunk, which ship their fixes under their own advisories (Inferred from [20] [18] [70] [74] [24] [28] [35] [31] [33]).

## Vendor advisories and what they cover

| Vendor | Advisory | What it says is affected | Fix | Source |
|---|---|---|---|---|
| AWS | 2026-150-AWS (24 Oct, updated 5 Nov) | Trust bundles in CloudFront, ALB OIDC, STS, Cognito, RDS for SQL Server, EMR, Lambda, Amplify, Windows and EKS AMIs, CodeBuild, Network Firewall TLS inspection, Fargate and ECS, Bottlerocket, Amazon Linux, Corretto, boto3 and botocore | Bottlerocket 1.68.0; EKS nodes release v20261023 or later; boto3 and botocore 1.43.117; ALB OIDC and JWT customers by 28 October | [18] |
| Cisco | cisco-sa-emudhra-info-ScS22A1r (23 Oct to v1.9, 10 Nov) | Dozens of products: IOS and IOS XE, Secure Firewall ASA, FMC and FTD, ISE, IOS XR, IP phones, Meraki MV cameras, Duo gateways, ThousandEyes agents, Cyber Vision, Ultra packet core, Webex and RoomOS | Fixed releases with target dates into 2027; many products under investigation; no workarounds | [31] |
| Microsoft | MSRC blog (26 Oct, updated 27 Oct and 10 Nov) | Windows (disconnected devices especially), Edge, WebView2, Azure images, .NET, Microsoft Build of OpenJDK, APIM self-hosted gateway | Disallowed list, out-of-band and November updates; NuGet.org blocks the certificates on upload | [24] |
| Splunk | SVD-2026-1014 (27 Oct) | About 90 products carry an eMudhra public certificate in a CA trust store, among them Splunk Enterprise, Cloud, ES, SOAR and AppDynamics | Universal Forwarder unaffected | [33] |
| Cloudflare | Blog (20 Oct) | Cloudflare One and WARP, the 1.1.1.1 app, cloudflared, mTLS trust stores, Containers | cloudflared 2026.10.2 and client updates | [29] |
| Python | discuss.python.org (20 Oct) | pip loads its vendored certifi bundle in addition to the OS store, with no supported way to turn that off | pip 26.2.2, certifi 2026.10.19, uv 0.13.6, patched Python releases | [35] |
| Go | GO-2026-6809 (21 Oct) | `crypto/x509` | Go 1.26.10 and 1.27.3 | [21] |
| Red Hat | RHSB-2026-012 (21 Oct, updated 31 Oct) | The ca-certificates trust store in RHEL 6 to 10 and products and containers built on them | Updated ca-certificates packages; rebuild containers on updated base images | [70] |
| Oracle | Security Alert CVE-2026-91403 (21 Oct) | Java SE and GraalVM trust stores | Java updates that distrust the eMudhra intermediates | [71] |
| Cisco Talos | Blog (21 Oct) | Software with independent CA stores | Snort SIDs 67363 to 67374 | [32] |

## The client-path exposure gap

A browser and a server's outbound client are different trust stores with different update paths. The browser root programs blocked the intermediates within hours, but Python's pip trusts its vendored certifi bundle whatever the operating system says (**Confirmed** [35]); macOS tools that read `/etc/ssl/cert.pem`, among them curl, git, python3, ruby, perl and openssl, skipped Apple's block until macOS 27.2.1, 26.7.3 and 15.8.3 removed five roots from that file (**Confirmed** [28]); Windows devices that cannot reach Microsoft's certificate update service need the trusted root payload delivered another way, which is what KB5134133 carries for Windows 11 (**Confirmed** [25] [24]); and Go programs need a rebuild against the fixed toolchain (**Confirmed** [21]). The community explainer puts it plainly: CT-enforcing browsers could not have been attacked, but many non-browser clients do not enforce CT, and whether they were attacked is unknown (**Confirmed** [4]).

Cloudflare's measurements show the size of the gap about two weeks in: more than half of probes from large networks and 30 to 40 percent of embedded browsers still accepted the chain (**Confirmed** [30]). The gap between a fixed browser and an unfixed client is the window a server-to-server attacker would use, and a vulnerability program that measures browsers and operating system patch levels can report the incident closed while it is open (Inferred). The method for finding each trust store is in Certificate Trust Incident Response; the same long-tail pattern drove Log4Shell, where copies inside other software outlived the fix by years.

## Prioritizing the work

Rank client paths by what they connect to: outbound calls to identity providers, payment and package registries, and webhooks are where a forged certificate would do most harm (Inferred). AWS's 28 October deadline for ALB OIDC and JWT customers is an example of a provider ranking its own identity path first (**Confirmed** [18] for the deadline; Inferred for the reading). See the Vulnerability Prioritization Reference.

# Part 8: the defender view

## Remediation by platform and capability

| Platform or capability | What shipped | What to do | Source |
|---|---|---|---|
| Chrome desktop | CRLSet block 17 Oct; root removal 27 Oct; G1 SCT cutoff from Chrome 153 | Keep Chrome current; the CRLSet needs no update or restart | [3] |
| Android and Googlebooks | Play Services block about 22:00 UTC 19 Oct | Restart the device to pull it immediately | [3] |
| Firefox | OneCRL 17 Oct; 158.0.1, ESR 115.43.1 and ESR 153.5.1 for configurations that block OneCRL; Android 158.0.2 | Update, especially where OneCRL is disabled by policy | [2] |
| NSS consumers | NSS 3.131.1 removes the signing root | Update applications that use Mozilla's store without OneCRL | [2] |
| Windows | Disallowed list 20 Oct; out-of-band update 26 Oct (KB5134133 for Windows 11; KB5134125 for Windows 10 reported); November security update; 10 more roots from 16 Nov | Keep automatic trust updates on; deliver the disallowed list to disconnected devices following Microsoft Learn; review disconnected Azure VMs; replace certificates chaining to removed roots | [24] [25] [26] [27] |
| Edge and WebView2 | CRLSet; seven certificates removed 27 Oct; four roots from 16 Nov | Keep the component updates flowing | [24] |
| Apple | Automatic configuration updates block 12 TLS intermediate certificates and emSign ECC Root CA - G3 for Safari, Mail and apps using Apple's frameworks; Apple's frameworks do not trust the two code-signing CAs | Update; for command-line tools install macOS 27.2.1, 26.7.3 or 15.8.3, or push the root removal by device management and re-check after every update | [28] |
| Go | Go 1.26.10 and 1.27.3 | Rebuild and redeploy Go binaries | [21] |
| Python | pip 26.2.2, certifi 2026.10.19, uv 0.13.6, patched Python releases | Upgrade pip in every virtual environment; rebuild container images with the cache disabled | [35] |
| AWS services | Root removal in the shared trust store 21 Oct; Bottlerocket 1.68.0; EKS v20261023; botocore 1.43.117 | Update node images and SDKs; ALB OIDC and JWT customers replace identity-provider certificates | [18] |
| Network appliances | Cisco fixes by product into 2027, no workarounds | Track each product's fixed release; apply compensating controls where none exists yet | [31] [34] |
| Code signing | Two code-signing CAs revoked; Microsoft blocks them; NuGet.org rejects them on upload | Treat anything signed under them as unverified (Inferred) | [1] [24] |
| Site operators under G3 | eMudhra stopped G3 issuance; Sectigo offered | Reissue from another hierarchy before the root removals break validation | [1] [14] |

Three principles hold across the table. Block by key and by every path, because the Sectigo cross-certificates keep a path open after one root is removed (**Confirmed** [28]). Rebuild anything immutable, because a container keeps the bundle it was built with (**Confirmed** for pip in images [35]; Inferred in general). Verify by test, not by version (**Confirmed** [34]).

### CERT-In's checklist

CERT-In's advisory CIAD-2026-0050 asks organizations to confirm that systems receive revocation and distrust updates; to inventory certificates chaining to the intermediates or to G3, including cross-signed chains; to review independent trust stores in applications, runtimes, container images, TLS libraries, network appliances and embedded devices; to apply compensating controls where vendor support is missing; to verify that applications reject the compromised chains; to monitor CT, noting that CT supplements revocation and trust-store controls and does not replace them; and to tell users not to bypass certificate warnings (**Confirmed** [34]). The advisory does not mention certificate pinning (**Confirmed** [34]).

### Detection

- **Certificate Transparency monitoring.** Watch CT for certificates chaining to the eight intermediates or to G3; Unit 42 suggests crt.sh (**Confirmed** [36] [34]). CT catches certificates someone chose to log, so it shows tests and careless use, not a careful attacker serving an unlogged certificate to a client that never checks (Inferred from [4]).
- **Network signatures.** Talos published Snort SIDs 67363 to 67374 for the incident (**Confirmed** [32]).
- **Proxies and gateways.** Unit 42 recommends strict CRL and OCSP checking on proxies and gateways, trust stores deployed through device management, and audits of custom stores such as Java keystores, certifi, Docker images and mobile bundles (**Confirmed** [36]).
- **Test from each client path.** Confirm that a connection presenting the compromised chain is refused and a known-good endpoint still validates (**Confirmed** as CERT-In's advice [34]).

### What does not help

Unit 42 also recommends CAA records and short-lived certificates (**Confirmed** [36]). CAA does not stop someone who holds a compromised intermediate key: the issuing CA's own process checks CAA, and a key holder signs outside that process (Inferred). Short-lived certificates limit how long a stolen leaf is useful, not how long a stolen CA key is (Inferred).

## Part 9: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND. Every id was checked against the live ATT&CK page or the library's data files on 11 November 2026 [65] [66] [67] [68] [69]. No advisory or root program in the record names an ATT&CK id, and Unit 42 cites none (**Confirmed** [36]); every mapping below is this study's own and is graded Inferred, while each id, name and tactic is Confirmed. The record contains no adversary behavior at all: the actions that happened were key recovery and certificate forging by researchers and testers, and everything else is capability. The study labels each row accordingly. The incident touches industrial devices only as products that carry a trust store (Talos's industrial IoT, Cisco's Cyber Vision), and no ATT&CK for ICS technique is supported by the record.

## ATT&CK Enterprise techniques

| Id | Name | Tactic (v20.0) | Where it appears in the eMudhra record | Status | Source |
|---|---|---|---|---|---|
| T1588.004 | Digital Certificates (Obtain Capabilities) | Resource Development | Key recovery by the reporter (17 Oct, 16:27), Mozilla (17 Oct, 21:48) and multiple individuals, some publicly (20 Oct). The ATT&CK page covers stealing certificate materials "including from certificate authorities" and cites DigiNotar | Happened, by researchers; no adversary observed | [1] [37] [65] |
| T1649 | Steal or Forge Authentication Certificates | Credential Access | Forged certificates under the recovered keys: a google.com subdomain (20 Oct, 12:15) and the certificate Cloudflare saw dated 20 Oct, 18:19. The technique text covers adversaries with root or subordinate CA private keys forging arbitrary authentication certificates for a victim domain; it is framed around authentication certificates, so the fit to TLS server certificates is partial | Happened: one public demonstration (q3k) and one forged certificate Cloudflare saw without attribution; no malicious use confirmed | [37] [30] [67] |
| T1557 | Adversary-in-the-Middle | Credential Access, Collection | The capability Google, Mozilla and CERT-In name: impersonating websites and reading or modifying traffic. Cloudflare found no interception of its connections | Capability, not observed | [3] [2] [34] [30] |
| T1588.003 | Code Signing Certificates | Resource Development | Two code-signing intermediates, EM OV CS CA - G3B and G3C, trusted by Microsoft | Capability, not observed | [1] [34] |
| T1553.002 | Code Signing | Defense Impairment | CERT-In: malware could appear signed by a trusted publisher; Microsoft blocks the two CAs and NuGet.org rejects them | Capability, not observed | [34] [24] |
| T1587.003 | Digital Certificates (Develop Capabilities) | Resource Development | Proof-of-concept certificates logged to CT on 20 and 21 Oct (about 107,107 by one commenter's count) fit the technique in form only | Form only; researchers | [1] [39] |
| T1608.003 | Install Digital Certificate | Resource Development | Origins that set up certificates for themselves under the weak intermediate, seen in Cloudflare's handshake logs | Form only; testers | [30] |

Considered and not bound: T1553.004 Install Root Certificate, listed under Defense Impairment (TA0112) on the live page, covers roots installed on endpoints, not the compromise of a public CA's key, and its mitigation M1054 recommends key pinning. It applies here only by contrast, since defenders removed roots, so it is not bound as an observed technique and is left out of the layer (**Confirmed** [66] [67]; Inferred for the judgment).

## ATT&CK groups, software and campaigns

None. No opened primary ties an ATT&CK group, software or campaign object to this event (**Confirmed** [3] [2] [1] [24] [31] [32] [34] [36]). The reporter and the testers who recovered the keys are researchers, and binding them to an ATT&CK group would overstate the record. See Threat Actors and Malware Families for the library's actor and software references.

## CWE and CAPEC

| Weakness | Name | Who assigns it | CAPEC in the library | Source |
|---|---|---|---|---|
| CWE-299 | Improper Check for Certificate Revocation | The Go CNA on CVE-2026-111943, for the client-side denylist | None: the library's `data/weaknesses/cwe.jsonl` gives CWE-299 no related CAPEC entries | [20] [69] |
| CWE-295 | Improper Certificate Validation | Red Hat on CVE-2026-114406 and CPANSec on CVE-2026-113812, for trust stores that still accepted the chain | The library relates CAPEC-459 Creating a Rogue Certification Authority Certificate and CAPEC-475 Signature Spoofing by Improper Validation; both describe other mechanisms (hash collisions, weak signature verification), so neither is bound here (Inferred) | [72] [73] [69] |
| CWE-330 | Use of Insufficiently Random Values | No primary record assigns it; it matches AWS's "entropy failures" and Google's "insufficient randomness" by description (Inferred). eMudhra's own account, a script that re-created weak key objects, is a handling defect rather than a random number generator failure, so the fit is to the outcome, not the mechanism (Inferred) | CAPEC-485 Signature Spoofing by Key Recreation, whose description (a signer's private key recovered through a weakness in random number generation, then used to forge signatures) matches the event (Inferred); CAPEC-112 Brute Force, recovering a secret from at most 256 candidates (Inferred) | [18] [3] [1] [69] |
| CWE-331 | Insufficient Entropy | No primary record assigns it; same reading as CWE-330 (Inferred) | The library relates only CAPEC-59, which concerns session identifiers and is not used here | [69] |

Two more CAPEC entries apply as capability, through the techniques above: CAPEC-94 Adversary in the Middle (AiTM), which the library maps to T1557, and CAPEC-473 Signature Spoof, which it maps to T1553.002 (**Confirmed** for the library data [69]; Inferred for the pairing). CAPEC-479 Malicious Root Certificate, mapped to T1553.004, is the contrast case and is not bound. The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

## D3FEND countermeasures

| Countermeasure | Id | Library mappings to this study's techniques | eMudhra guidance it matches | Source |
|---|---|---|---|---|
| Certificate Analysis | D3-CA | T1649 | CT monitoring (CERT-In, Unit 42); weak-key screening of CA certificates (Chrome's paranoid_crypto, CCADB-Tools#185) | [68] [34] [36] [1] |
| Certificate Rotation | D3-CERO | T1649 | Migrating the roughly 30,000 certificates under G3 and reissuing elsewhere (Inferred pairing) | [68] [1] [14] |
| Certificate Pinning | D3-CP | T1649 | ATT&CK's M1054 on T1553.004 recommends key pinning; CERT-In does not mention pinning. Pinning a server key, not a CA, is what would have resisted a forged certificate (Inferred) | [68] [66] [34] |
| Credential Revocation | D3-CR | Not mapped to these techniques | Revoking the eight intermediates, the cross-certificates and the RSA set; OneCRL and CRLSet (Inferred pairing) | [68] [1] [2] [3] |
| Software Update | D3-SU | T1649 | Firefox, Go, pip, macOS and Windows updates | [68] [2] [21] [35] [28] [24] |
| Software Inventory | D3-SWI | T1649 | Inventorying independent trust stores (CERT-In) | [68] [34] |
| Asset Vulnerability Enumeration | D3-AVE | T1649 | Matching products to vendor lists such as Cisco's and Splunk's (Inferred pairing) | [68] [31] [33] |
| Network Traffic Signature Analysis | D3-NTSA | T1557 | Talos's Snort SIDs 67363 to 67374 | [68] [32] |
| Executable Allowlisting | D3-EAL | Not mapped to these techniques | Refreshing the code-signing trust that verifiers use (Inferred pairing) | [68] [24] |

Of these, Certificate Analysis, Certificate Rotation, Certificate Pinning, Software Update, Software Inventory and Asset Vulnerability Enumeration are mapped to T1649 in the library's `d3fend_countermeasures.jsonl`, and Network Traffic Signature Analysis to T1557; Credential Revocation, the countermeasure the root programs actually used first, is not mapped to any technique in this study, so pairing it with the event is this study's reading (**Confirmed** for the data [68]; Inferred for the pairing).

## Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/emudhra-ca-compromise-2026.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 and scores each technique by what the record shows: 50 where the action happened, by researchers and testers (key recovery, certificate forging), 25 for a capability the primaries name that no one observed (adversary-in-the-middle, code signing), and 10 for a form-only fit (proof-of-concept and self-issued certificates). No technique carries a score for adversary use, because none was observed. Install Root Certificate is left out because it fits only by contrast. Each entry's comment names the source numbers above.

## Cross-cutting themes

- **Key generation is attack surface.** P-384 was never at issue; the keys were weak because a script handled them badly and nothing checked the result (**Confirmed** [1] [34]). Any process that moves or re-creates key material outside an HSM is part of the attack surface, and a key-strength check plus a comparison of the certified key with the generated one are cheap controls (Inferred from [1] comment 82). See the Cryptography Reference and Cryptography and PKI.
- **Signing keys are the crown jewels, wherever they come from.** The Stuxnet and SolarWinds SUNBURST studies record signing material abused by intruders (sources and grades there); here the signing keys were not stolen but simply guessable (Inferred for the comparison).
- **Trust is federated, and so is remediation.** Browsers, operating systems, language runtimes, containers, appliances and embedded devices each decide trust independently; the same incident produced a fix in two hours for Chrome and target dates in 2027 for some Cisco products (**Confirmed** [3] [31]).
- **Certificate Transparency did its job, inside its boundary.** CT is why Google could say no forged certificate reached Chrome users, and why researchers' proof-of-concept certificates were visible within a day; it says nothing about clients that do not enforce it (**Confirmed** [3] [1] [4]; Inferred for the boundary).
- **Scanners see what is logged.** The weak keys sat in dormant intermediates that never logged a leaf, outside the one pipeline that would have caught them (**Confirmed** [1] comment 50). Monitoring that keys on activity misses assets that are trusted but idle (Inferred).
- **Small anomalies are signals.** A CRL that did not verify in June 2025 was the defect showing itself 16 months before the report (**Confirmed** [9] [1]). A fix at the symptom level closed the ticket and left the cause (Inferred).
- **Recovery is cheap now.** Mozilla's note that local AI agents recovered the keys from a simple prompt means the time from "weak key is public" to "weak key is used" is short for everyone (**Confirmed** [1]; Inferred for the implication). See AI Threats 2026.

### What is overstated and what is understated

- **Overstated: "eMudhra's root keys were compromised" and "all eMudhra certificates are compromised".** Eight intermediate keys were weak; no primary says a root key was compromised, the roots were distrusted as a precaution, and the G1 root keeps serving certificates issued before its cutoff (**Confirmed** [1] [3] [24]; Inferred for the reading).
- **Overstated: "the keys were stolen".** No primary reports anything taken from eMudhra: the keys were generated weak and could be computed from public data, and eMudhra states there was no infrastructure compromise (**Confirmed** as eMudhra's statement [1] [17]).
- **Overstated: "confirmed interception".** Every primary, from Google, Mozilla, Microsoft, Apple, CERT-In, Talos and Cloudflare, stops at capability or at no evidence, and the post-disclosure CT volume is researcher proof-of-concept traffic (Inferred from [3] [2] [24] [28] [34] [32] [30] [39]).
- **Overstated: identifiers.** CVE-2026-111943 is Go's `crypto/x509` record and does not name eMudhra, and CVE-2026-111944 does not exist (**Confirmed** [20] [22]).
- **Overstated: CAA as a defense.** It does not bind a key holder (Inferred from [36]).

- **Understated: the long tail.** Embedded web views, IoT, appliances, pinned language bundles, macOS `cert.pem` and air-gapped Windows trusted the chain after browsers stopped, and more than half of probes from large networks still accepted it about two weeks in (**Confirmed** [30] [28] [35] [24]; Inferred for the list as a whole).
- **Understated: the window before disclosure.** The weak keys existed from 30 April 2025 to 17 October 2026, and CT alone cannot rule out covert use against clients that do not enforce it (Inferred from [1] [4]).
- **Understated: what the audits and checks missed.** The weak keys passed CCADB disclosure, a cross-signature by another CA and audit cycles, and the A series is missing from the 2024-25 audit reports (Inferred from [1]; **Confirmed** for the A series bug [10]).
- **Understated: the RSA set.** Eight RSA intermediates from the same ceremony were revoked too, and two had issued end-entity certificates (**Confirmed** [1]).

## Sources

All sources were opened on 11 November 2026. Grades apply to the source as used here. Bug 2083449 is cited by comment number in the text.

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 1 | Mozilla Bugzilla 2083449, "eMudhra: Private key compromise of Intermediate Certificates" (CA Certificate Compliance; comments 0 to 92, including eMudhra's Full Incident Report, comment 82, and the Chrome Root Program review, comment 50) | bugzilla.mozilla.org/show_bug.cgi?id=2083449 | 2026-11-11 | Confirmed (commenters' claims graded Reported in the text) |
| 2 | Mozilla Security Blog, "Protecting Firefox users following the compromise of eMudhra intermediate certificates", 20 Oct 2026 | blog.mozilla.org/security/2026/10/20/... | 2026-11-11 | Confirmed |
| 3 | Google, "Protecting Chrome and Android users from compromised eMudhra intermediate CA certificates", 20 Oct 2026, updated 4 Nov 2026 | blog.google/security/protecting-chrome-and-android-users-from-compromised-emudhra-intermediate-ca-certificates/ | 2026-11-11 | Confirmed |
| 4 | Community explainer and test site, dated 20 Oct 2026, updated 10 Nov 2026 | emudhra.we-have-a-problem.com | 2026-11-11 | Confirmed |
| 5 | Mozilla dev-security-policy, "Compromised eMudhra Intermediate Certificates", 20 Oct 2026 | groups.google.com/a/mozilla.org/g/dev-security-policy/c/0R3XLJL6FuE/m/VAgSvefvAAAJ | 2026-11-11 | Confirmed |
| 6 | oss-security, Mozilla's notice to trust store operators, 20 Oct 2026 | openwall.com/lists/oss-security/2026/10/20/1 | 2026-11-11 | Confirmed |
| 7 | Mozilla Bugzilla 2084101, "Remove eMudhra emSign Root CA - G3 from NSS" | bugzilla.mozilla.org/show_bug.cgi?id=2084101 | 2026-11-11 | Confirmed |
| 8 | Mozilla Bugzilla 2089115, emSign Root CA - G1 email trust removal and TLS distrust-after | bugzilla.mozilla.org/show_bug.cgi?id=2089115 | 2026-11-11 | Confirmed |
| 9 | Mozilla Bugzilla 1970728, "eMudhra: Invalid CRL signatures", opened 5 Jun 2025 | bugzilla.mozilla.org/show_bug.cgi?id=1970728 | 2026-11-11 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 10 | Mozilla Bugzilla 2090128, "eMudhra: Series A intermediates missing from 2024-25 audit reports", opened 6 Nov 2026 | bugzilla.mozilla.org/show_bug.cgi?id=2090128 | 2026-11-11 | Confirmed |
| 11 | Mozilla Bugzilla 2085612, "eMudhra: Access to CRLs blocked for certain User-Agent headers", opened 25 Oct 2026 | bugzilla.mozilla.org/show_bug.cgi?id=2085612 | 2026-11-11 | Confirmed |
| 12 | Mozilla Bugzilla 2018979, eMudhra transition plan for dual-purpose roots | bugzilla.mozilla.org/show_bug.cgi?id=2018979 | 2026-11-11 | Confirmed |
| 13 | Mozilla dev-security-policy, notice of intent to approve eMudhra's inclusion request, 2 Oct 2026 | groups.google.com/a/mozilla.org/g/dev-security-policy/c/h2ucXHS5HZ4 | 2026-11-11 | Confirmed |
| 14 | eMudhra, certificate security incident page, first published 20 Oct 2026, last updated 5 Nov 2026 | emudhra.com/en/post/certificate-security-incident | 2026-11-11 | Confirmed (eMudhra's statements about itself) |
| 15 | eMudhra, press statement on the distrust, 21 Oct 2026 | emudhra.com/en/press-release/emudhra-statement-distrust-global-tls-intermediate-root-ca | 2026-11-11 | Confirmed |
| 16 | eMudhra, "eMudhra to exit global SSL/TLS certificate business", 22 Oct 2026 | emudhra.com/en/press-release/emudhra-to-exit-global-ssl-tls-certificate-business | 2026-11-11 | Confirmed |
| 17 | eMudhra, stock-exchange filing (NSE), 21 Oct 2026 | nsearchives.nseindia.com/corporate/EMUDHRA2008_21102026105726_Press_Release_21102026.pdf | 2026-11-11 | Confirmed |
| 18 | AWS Security Bulletin 2026-150-AWS, 24 Oct 2026, updated 5 Nov 2026 | aws.amazon.com/security/security-bulletins/rss/2026-150-aws/ | 2026-11-11 | Confirmed |
| 19 | Amazon Linux, CVE-2026-111943 | explore.alas.aws.amazon.com/CVE-2026-111943.html | 2026-11-11 | Confirmed |
| 20 | CVE record CVE-2026-111943 (CVE Services API; CNA Go, with CISA ADP) | cveawg.mitre.org/api/cve/CVE-2026-111943 | 2026-11-11 | Confirmed |
| 21 | Go vulnerability report GO-2026-6809 | pkg.go.dev/vuln/GO-2026-6809 | 2026-11-11 | Confirmed |
| 22 | CVE Services API, CVE-2026-111944 (returns CVE_RECORD_DNE) | cveawg.mitre.org/api/cve/CVE-2026-111944 (plain text: the API answers 404 with CVE_RECORD_DNE, which is what this row cites) | 2026-11-11 | Confirmed |
| 23 | Qualys, post on identifying compromised eMudhra certificates, 23 Oct 2026 | blog.qualys.com/product-tech/2026/10/23/... | 2026-11-11 | Confirmed (for what the post says) |
| 24 | Microsoft Security Response Center, "Microsoft response to compromised eMudhra certificate authority keys", 26 Oct 2026, updated 27 Oct and 10 Nov 2026 | microsoft.com/en-us/msrc/blog/2026/10/... | 2026-11-11 | Confirmed |
| 25 | Microsoft, KB5134133, Windows 11 24H2, 25H2 and 26H2 out-of-band update, 26 Oct 2026 | support.microsoft.com/en-us/servicing/os/windows-11/2026/10/kb5134133-... | 2026-11-11 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 26 | Microsoft 365 Message Center MC1529467, admin guidance, 28 Oct 2026 (public mirror) | mc.merill.net/message/MC1529467 | 2026-11-11 | Confirmed |
| 27 | BleepingComputer, Windows out-of-band updates to distrust eMudhra certificates, 27 Oct 2026 | bleepingcomputer.com/news/microsoft/... | 2026-11-11 | Reported |
| 28 | Apple, support article 149555, 9 Nov 2026 | support.apple.com/en-us/149555 | 2026-11-11 | Confirmed |
| 29 | Cloudflare, eMudhra certificate compromise explainer, 20 Oct 2026 | blog.cloudflare.com/emudhra-certificate-compromise/ | 2026-11-11 | Confirmed |
| 30 | Cloudflare, tracking exploitation and patching of eMudhra's weak keys, 30 Oct 2026 | blog.cloudflare.com/emudhra-patching/ | 2026-11-11 | Confirmed |
| 31 | Cisco, informational advisory cisco-sa-emudhra-info-ScS22A1r, v1.0 23 Oct 2026 to v1.9 10 Nov 2026 | sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-emudhra-info-ScS22A1r | 2026-11-11 | Confirmed (Reported where it describes third parties) |
| 32 | Cisco Talos, "Compromised eMudhra intermediate certificates", 21 Oct 2026 | blog.talosintelligence.com/compromised-intermediate-certificates/ | 2026-11-11 | Confirmed |
| 33 | Splunk, advisory SVD-2026-1014, 27 Oct 2026 | advisory.splunk.com/advisories/SVD-2026-1014 | 2026-11-11 | Confirmed |
| 34 | CERT-In, advisory CIAD-2026-0050, 21 Oct 2026 | cert-in.org.in/s2cMainServlet?pageid=PUBVLNOTES02&VLCODE=CIAD-2026-0050 | 2026-11-11 | Confirmed |
| 35 | Python discussion forum, "Information for Python users regarding eMudhra emSign CA certificate security incident", 20 Oct 2026 | discuss.python.org/t/.../109576 | 2026-11-11 | Confirmed |
| 36 | Palo Alto Networks Unit 42, "eMudhra Intermediate CA Certificates Compromised", 22 Oct 2026 | unit42.paloaltonetworks.com/emudhra-certificate-compromise/ | 2026-11-11 | Confirmed |
| 37 | Public post by q3k demonstrating independent key recovery, 20 Oct 2026, 12:15 UTC | social.hackerspace.pl/@q3k/117473185371937796 (plain text: on 11 November 2026 the host failed DNSSEC validation, so automated link checks cannot reach it; the post was opened by the host's address) | 2026-11-11 | Demonstrated |
| 38 | OffSec, blog post on the eMudhra certificate compromise | offsec.com/blog/emudhra-certificate-compromise/ | 2026-11-11 | Reported |
| 39 | SecurityOnline, rogue eMudhra certificates in CT logs, 26 Oct 2026 | securityonline.info/emudhra-rogue-certificates-ct-logs/ (plain text: the host times out for automated link checks) | 2026-11-11 | Reported |
| 40 | CA/Browser Forum, Server Certificate Working Group minutes, 22 Oct 2026 | cabforum.org/2026/10/22/2026-10-22-minutes-of-the-server-certificate-working-group/ | 2026-11-11 | Confirmed |
| 41 | Controller of Certifying Authorities, licensed CAs | cca.gov.in/licensed_ca.html | 2026-11-11 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 42 | Controller of Certifying Authorities, about the CCA | cca.gov.in/about.html | 2026-11-11 | Confirmed |
| 43 | Controller of Certifying Authorities, eSign | cca.gov.in/eSign.html | 2026-11-11 | Confirmed |
| 44 | ICRA, eMudhra rating rationale, 6 Jun 2024 | icra.in/Rating/GetRationalReportFilePdf?id=128000 | 2026-11-11 | Confirmed |
| 45 | Business Today, MeitY on the eMudhra incident, 21 Oct 2026 | businesstoday.in/technology/story/... | 2026-11-11 | Reported |
| 46 | All India Radio (newsonair), MeitY on the eMudhra incident, 22 Oct 2026 | newsonair.gov.in/meity-says-impact-of-emudhra-security-incident-on-indian-websites-apps-very-limited/ | 2026-11-11 | Reported |
| 47 | CCADB, Incident Reporting Guidelines v3.2 | ccadb.org/cas/incident-report | 2026-11-11 | Confirmed |
| 48 | Mozilla Root Store Policy v3.1 | mozilla.org/en-US/about/governance/policies/security-group/certs/policy/ | 2026-11-11 | Confirmed |
| 49 | Chrome Root Program Policy v1.8 | googlechrome.github.io/chromerootprogram/crp/policy | 2026-11-11 | Confirmed |
| 50 | Chrome Certificate Transparency policy | googlechrome.github.io/CertificateTransparency/ct_policy.html | 2026-11-11 | Confirmed |
| 51 | RFC 6962, Certificate Transparency, June 2013 | rfc-editor.org/rfc/rfc6962.html | 2026-11-11 | Confirmed |
| 52 | Chromium ct-policy group, CT enforcement notice to CAs, 6 Feb 2018 | groups.google.com/a/chromium.org/g/ct-policy/c/wHILiYf31DE | 2026-11-11 | Confirmed |
| 53 | Google Security Blog, attempted man-in-the-middle attacks (DigiNotar), 29 Aug 2011 | security.googleblog.com/2011/08/update-on-attempted-man-in-middle.html | 2026-11-11 | Confirmed |
| 54 | Mozilla Security Blog, fraudulent google.com certificate, 29 Aug 2011 | blog.mozilla.org/security/2011/08/29/fraudulent-google-com-certificate/ | 2026-11-11 | Confirmed |
| 55 | Government of the Netherlands, information about DigiNotar, 5 Sep 2011 | rijksoverheid.nl/documenten/brochures/2011/09/05/informatie-over-diginotar | 2026-11-11 | Confirmed |
| 56 | SecurityWeek, on Fox-IT's DigiNotar interim report | securityweek.com/hacker-had-total-control-over-diginotar-servers-report | 2026-11-11 | Reported |
| 57 | Google Security Blog, "Sustaining digital certificate security" (Symantec), 28 Oct 2015 | security.googleblog.com/2015/10/sustaining-digital-certificate-security.html | 2026-11-11 | Confirmed |
| 58 | Mozilla Security Blog, "Distrusting new WoSign and StartCom certificates", 24 Oct 2016 | blog.mozilla.org/security/2016/10/24/distrusting-new-wosign-and-startcom-certificates/ | 2026-11-11 | Confirmed |
| 59 | Google Security Blog, "Distrusting WoSign and StartCom", 31 Oct 2016 | security.googleblog.com/2016/10/distrusting-wosign-and-startcom.html | 2026-11-11 | Confirmed |
| 60 | Google Security Blog, "Chrome's plan to distrust Symantec", 11 Sep 2017 | security.googleblog.com/2017/09/chromes-plan-to-distrust-symantec.html | 2026-11-11 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 61 | Mozilla dev-security-policy, TrustCor distrust proposal, 8 Nov 2022 | groups.google.com/a/mozilla.org/g/dev-security-policy/c/oxX69KFvsm4/m/yLohoVqtCgAJ | 2026-11-11 | Confirmed |
| 62 | Mozilla Bugzilla 1803453, TrustCor distrust-after dates | bugzilla.mozilla.org/show_bug.cgi?id=1803453 | 2026-11-11 | Confirmed |
| 63 | Google Security Blog, "Sustaining digital certificate security" (Entrust), 27 Jun 2024, updated 10 Sep 2024 | security.googleblog.com/2024/06/sustaining-digital-certificate-security.html | 2026-11-11 | Confirmed |
| 64 | Mozilla dev-security-policy, Entrust distrust decision, 31 Jul 2024 | groups.google.com/a/mozilla.org/g/dev-security-policy/c/jCvkhBjg9Yw | 2026-11-11 | Confirmed |
| 65 | MITRE ATT&CK v20, T1588.004 Obtain Capabilities: Digital Certificates | attack.mitre.org/techniques/T1588/004/ | 2026-11-11 | Confirmed |
| 66 | MITRE ATT&CK v20, T1553.004 Subvert Trust Controls: Install Root Certificate | attack.mitre.org/techniques/T1553/004/ | 2026-11-11 | Confirmed |
| 67 | TeamStarWolf library data, `data/attack/technique_profiles.jsonl` and the `mitre/techniques/` pages | github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre/techniques | 2026-11-11 | Confirmed |
| 68 | TeamStarWolf library data, `data/attack/technique_to_d3fend.jsonl` and `data/attack/d3fend_countermeasures.jsonl`, and the `mitre/d3fend/` pages | github.com/TeamStarWolf/TeamStarWolf/blob/main/mitre/d3fend/certificate-analysis.md | 2026-11-11 | Confirmed |
| 69 | TeamStarWolf library data, `data/weaknesses/cwe.jsonl` and `data/weaknesses/capec.jsonl` | github.com/TeamStarWolf/TeamStarWolf/blob/main/data/weaknesses/cwe.jsonl | 2026-11-11 | Confirmed |
| 70 | Red Hat, security bulletin RHSB-2026-012, "Certificate compromise - eMudhra", 21 Oct 2026, updated 31 Oct 2026 | access.redhat.com/security/vulnerabilities/RHSB-2026-012 | 2026-11-11 | Confirmed |
| 71 | Oracle, Security Alert Advisory CVE-2026-91403 | oracle.com/security-alerts/alert-cve-2026-91403.html | 2026-11-11 | Confirmed |
| 72 | CVE record CVE-2026-114406 (CVE Services API; CNA Red Hat) | cveawg.mitre.org/api/cve/CVE-2026-114406 | 2026-11-11 | Confirmed |
| 73 | CVE record CVE-2026-113812 (CVE Services API; CNA CPANSec) | cveawg.mitre.org/api/cve/CVE-2026-113812 | 2026-11-11 | Confirmed |
| 74 | CVE record CVE-2026-113470 (CVE Services API; CNA Mozilla) | cveawg.mitre.org/api/cve/CVE-2026-113470 | 2026-11-11 | Confirmed |
| 75 | CVE record CVE-2026-91403 (CVE Services API; CNA Oracle) | cveawg.mitre.org/api/cve/CVE-2026-91403 | 2026-11-11 | Confirmed |

Could not be opened: Mozilla's OneCRL tracking bug for this incident (access restricted), Fox-IT's DigiNotar interim report (the government address no longer serves it, so its count is cited through SecurityWeek [56]), and Microsoft's KB5134125 page for Windows 10 (cited through BleepingComputer [27]). Apple's start date for its block and its G1 removal date are given only by the community explainer site [4] and by eMudhra [14].

*© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation.*

*This project is not affiliated with or endorsed by MITRE.*

*© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/*

*© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/*

*© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/*

*The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.*

## Related references

- Certificate Trust Incident Response (the method this incident illustrates), Cryptography Reference, Cryptography and PKI
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Malware Families, Notable Incidents
- Vulnerability Prioritization Reference, Vulnerability Management Reference, Incident Response Reference
- Supply Chain Security Reference, Container Security Reference, Cloud Security Reference, Firmware and IoT Security Reference
- Related case studies: Stuxnet, SolarWinds SUNBURST, Log4Shell, AI Threats 2026
- Techniques: T1588.004 Digital Certificates, T1649 Steal or Forge Authentication Certificates, T1557 Adversary-in-the-Middle, T1588.003 Code Signing Certificates, T1553.002 Code Signing, T1587.003 Digital Certificates, T1608.003 Install Digital Certificate, T1553.004 Install Root Certificate (contrast only)
- CAPEC: CAPEC-485 Signature Spoofing by Key Recreation, CAPEC-112 Brute Force, CAPEC-94 Adversary in the Middle (AiTM), CAPEC-473 Signature Spoof
- D3FEND: Certificate Analysis, Certificate Rotation, Certificate Pinning, Credential Revocation
- Navigator layers, including this study's layer, emudhra-ca-compromise-2026.json
- All case studies